

Security+ 1.3 · Change Management

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 1.3** —
Change Management (11:22) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Change management ensures secure production changes. It involves documenting a Request for Change (RFC), assessing risk, obtaining approval from the Change Advisory Board (CAB), testing in an isolated environment, scheduling a window, having a rollback plan, notifying affected parties, and then executing, verifying, and documenting. Emergency changes follow a streamlined process but still require documentation.

High-Yield Core Concepts Tested on Exam

- Rollback plan: what to do if something goes wrong — without it, change is not approved
- Emergency change: fast-tracked CAB approval, but still documented
- All changes must go through a testing environment before production
- CAB (Change Advisory Board) approves changes
- RFC (Request for Change) initiates the process

Exam Tips & Classic Scenarios

- 'Requires rollback plan and testing before deployment' = change management
- 'Emergency change bypasses some approvals' = still needs documentation
- If the question mentions CAB, RFC, or rollback, think change management
- Testing in a sandbox is a key exam point

Typical Exam Scenario: A production server requires an application update. The technician must test the update in a staging environment and have a rollback plan before deployment. This is an example of change management.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 1.3 — Change Management)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. RTO (Recovery Time Objective) measures:

- A)** How much DATA you accept losing
- B)** How much TIME the service can be down
- C)** The cost of the incident
- D)** The number of affected users

2. The NIST CSF framework organizes security into 5 functions. What are they?

- A)** Install, Update, Test, Audit, Archive
- B)** Identify, Protect, Detect, Respond, Recover
- C)** Plan, Do, Check, Act, Review
- D)** Prevent, Punish, Predict, Prove, Publish

3. ISO/IEC 27001 is:

- A)** The INTERNATIONAL standard for information security management (ISMS)
- B)** A U.S. law
- C)** A type of firewall
- D)** A vulnerability scanner

4. Corporate scenario (Change Management): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.3), an analyst evaluates the following technical requirement: 'Rollback plan: what to do if it goes wrong — WITHOUT this, it's not approved.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: Rollback plan: what to do if it goes wrong — WITHOUT this, it's not approved.

5. Corporate scenario (Change Management): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.3), an analyst evaluates the following technical requirement: 'Emergency change: fast CAB, still documented'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Emergency change: fast CAB, still documented...
- D)** Allow shared access among administrators using generic credentials

6. Corporate scenario (Change Management): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.3), an analyst evaluates the following technical requirement: 'Every change goes through a TEST environment before production'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: Every change goes through a TEST environment before production...

7. Corporate scenario (Change Management): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.3), an analyst evaluates the following technical requirement: 'requires rollback plan and testing before deployment' = change management. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: 'requires rollback plan and testing before deployment' = change management.

8. Corporate scenario (Change Management): During a security review and compliance audit for the CompTIA Security+ exam (SY0-701, Section 1.3), an analyst evaluates the following technical requirement: 'emergency change bypasses some approvals' = still requires documentation'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'emergency change bypasses some approvals' = still requires documentation...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

9. Corporate scenario (Change Management): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.3), an analyst evaluates the following technical requirement: 'Typical scenario: application needs an update on the production server; the technician must test beforehand and have rollback' → change management. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Typical scenario: application needs an update on the production server; the technician...
- D)** Allow shared access among administrators using generic credentials

10. Corporate scenario (Change Management): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.3), an analyst evaluates the following technical requirement: 'Rollback plan: what to do if things go wrong — WITHOUT it, not approved'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Rollback plan: what to do if things go wrong — WITHOUT it, not approved...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — How much TIME the service can be down.

✓ **Why it's correct:** The correct answer is: how much TIME the service can be down. RTO (Recovery Time Objective) is a central metric in the Business Continuity Plan (BCP) and Disaster Recovery Plan (DRP), covered in the Business Continuity and Disaster Recovery domain of CompTIA Security+ SY0-701. It defines the maximum acceptable time to restore a service or process after an interruption, before the business impact becomes unacceptable. For example, if an e-commerce site sets an RTO of 2 hours, the recovery team must restore operations within 2 hours after the incident. RTO guides the choice of recovery strategies (hot site, warm site, cold site), backup frequency, and investments in redundancy. It is often confused with RPO, but while RTO measures downtime, RPO measures data loss.

✗ **Why the others are wrong:**

- *How much DATA you accept losing:* This is the definition of RPO (Recovery Point Objective), not RTO. RPO establishes the maximum amount of data that can be lost, measured in time (e.g., 15 minutes of transactions). It determines backup frequency: if the RPO is 1 hour, backups must occur at least every hour. RTO, on the other hand, focuses on service restoration time, not data loss. Confusing the two concepts leads to inadequate recovery strategies, as a low RPO does not guarantee a low RTO, and vice versa.
- *The cost of the incident:* The cost of the incident is a financial metric that quantifies direct and indirect losses resulting from an interruption (lost revenue, fines, productivity, reputational damage). Although it is an input to justify investments in continuity, it is not the definition of RTO. RTO is a time goal, not a monetary value. Using cost as the definition of RTO would divert focus from recovery planning, which needs clear temporal parameters to guide technical actions.
- *The number of affected users:* The number of affected users is an impact metric, useful for prioritization and communication, but it does not define RTO. RTO is a recovery time objective, regardless of the number of users. A service critical to few users may have a short RTO, while a service for many users may have a longer RTO, depending on business criticality. Therefore, this alternative does not correspond to the formal concept of RTO.

2) B — Identify, Protect, Detect, Respond, Recover.

✓ **Why it's correct:** The NIST Cybersecurity Framework (CSF) 2.0 organizes cybersecurity activities into five core functions: Identify, Protect, Detect, Respond, and Recover. These functions represent the complete lifecycle of cyber risk management. 'Identify' involves understanding the organizational context, assets, risks, and vulnerabilities. 'Protect' covers implementing safeguards to ensure delivery of critical services. 'Detect' defines activities to identify the occurrence of cybersecurity events. 'Respond' comprises actions taken after an incident is detected. 'Recover' focuses on restoring capabilities or services that were impaired. This framework is widely adopted and required in the Security Architecture and Design domain of the CompTIA Security+ (SY0-701) certification, specifically in objective 2.1, which deals with frameworks and guidelines.

✗ **Why the others are wrong:**

- *Install, Update, Test, Audit, Archive:* These terms describe generic steps of an IT operational process, such as a software lifecycle or patch management, but they do not constitute the NIST CSF functions. 'Install' and 'Update' refer to system deployment and maintenance; 'Test' is a verification activity; 'Audit' is a compliance assessment; and 'Archive' is a data retention practice. None of these actions correspond to the high-level strategic functions defined by the NIST CSF, which are risk-oriented rather than tactical tasks.
- *Plan, Do, Check, Act, Review:* This is a variation of the PDCA cycle (Plan-Do-Check-Act), used in

quality management and continuous improvement systems, such as ISO 9001. Although the NIST CSF can be integrated into continuous improvement processes, its five functions are not 'Plan, Do, Check, Act, Review'. PDCA is a generic management model, while CSF functions are specific to cybersecurity and have their own scope and definitions. The inclusion of 'Review' as a fifth step is a distortion, as the classic PDCA has four steps.

- *Prevent, Punish, Predict, Prove, Publish*: These terms are not part of any recognized cybersecurity framework. 'Prevent' is a goal, but not a CSF function; 'Punish' is a disciplinary or legal action, not a security function; 'Predict' is an aspirational goal, not an operational function; 'Prove' and 'Publish' are audit and communication actions, respectively, but they do not compose the NIST CSF structure. This alternative mixes concepts of justice, prediction, and disclosure, with no relation to the official functions of the framework.

3) A — The INTERNATIONAL standard for information security management (ISMS).

✓ **Why it is correct:** ISO/IEC 27001 is an international standard that specifies requirements for establishing, implementing, maintaining, and continually improving an Information Security Management System (ISMS). It is part of the ISO/IEC 27000 family, which addresses information security practices. The standard adopts a risk-based approach and is certifiable, allowing organizations to demonstrate compliance with global security standards. It is widely recognized and required in governance, risk, and compliance contexts, making it a relevant topic in the Governance, Risk, and Compliance domain of Security+ (SY0-701), objective 5.1.

✗ Why the others are wrong:

- *A U.S. law*: ISO/IEC 27001 is an international standard developed by the International Organization for Standardization (ISO) and the International Electrotechnical Commission (IEC), not a law. Laws are legislative acts of a country, such as HIPAA or GLBA in the U.S. ISO/IEC 27001 is a voluntary standard that can be adopted by organizations in any country, and its compliance is attested by certification, not by legal imposition. Confusing a standard with a law ignores the consensual and global nature of ISO standards.
- *A type of firewall*: ISO/IEC 27001 is not a security device or software, but a set of management requirements. Firewalls are network traffic control technologies, while ISO/IEC 27001 defines processes, policies, and controls for an ISMS. The standard covers organizational, human, and technical aspects, not limited to a specific technical solution. Reducing the standard to a type of firewall demonstrates a misunderstanding of its comprehensive and strategic scope.
- *A vulnerability scanner*: A vulnerability scanner is a technical tool that identifies flaws in systems, networks, or applications. ISO/IEC 27001, on the other hand, is a management standard that establishes a framework for governing information security as a whole. Although the standard may require the use of scanners as part of controls, it is not a tool. Confusing the standard with a scanner ignores its nature as a management system and its focus on continuous improvement and risk management.

4) D — Implement the corresponding solution: Rollback plan: what to do if it goes wrong — WITHOUT this, it's not approved..

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.3 (Change Management): Rollback plan: what to do if it goes wrong — WITHOUT this, it's not approved. A rollback plan is a critical component of change management, ensuring that if a change fails, the system can be reverted to its previous state. The best recommendation is to require a rollback plan as part of the change approval process.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and breaks

compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

5) C — Implement the corresponding solution: Emergency change: fast CAB, still documented....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.3 (Change Management): Emergency change: fast CAB, still documented. An emergency change is a change that must be implemented immediately to resolve a critical issue or security vulnerability. While it bypasses the normal change approval process, it still requires expedited review by the Change Advisory Board (CAB) and must be documented afterward to maintain audit trails and accountability.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

6) D — Implement the corresponding solution: Every change goes through a TEST environment before production....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.3 (Change Management): Every change goes through a TEST environment before production. This is a fundamental change management practice to ensure that changes are validated in a non-production environment before being deployed, reducing the risk of outages or security issues.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

7) D — Implement the corresponding solution: 'requires rollback plan and testing before deployment' = change management..

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.3 (Change Management): 'requires rollback plan and testing before deployment' = change

management. Change management is a structured process that ensures changes to IT systems are planned, tested, approved, and documented, with a rollback plan in case of failure. It minimizes disruptions and security risks. Security+ highlights change management as a key administrative control for maintaining system integrity and availability.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaches compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

8) A — Implement the corresponding solution: 'emergency change bypasses some approvals' = still requires documentation....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.3 (Change Management): 'emergency change bypasses some approvals' = still requires documentation.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who made critical changes or malicious commands.

9) C — Implement the corresponding solution: Typical scenario: application needs an update on the production server; the technician....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.3 (Change Management): Typical scenario: application needs an update on the production server; the technician must test beforehand and have rollback → change management. Change management ensures that changes are tested, approved, and can be rolled back if issues arise, minimizing disruption and security risks.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

10) B — Implement the corresponding solution: Rollback plan: what to do if things go wrong — WITHOUT it, not approved....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.3 (Change Management): Rollback plan: what to do if things go wrong — WITHOUT it, not approved. A rollback plan is a critical component of change management that outlines how to revert changes if they cause issues, and its absence should prevent approval of the change.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.